CYBER SECURITY — ASSIGNMENT # 1

Phishing Email Simulation & Awareness

Instructor	**Hafiz Usama Ishtiaq**
Assignment No.	**1**
Total Marks and Section	**100, E4**
Deadline	**21-10-26 (09:30 AM) — no extension will be given**
Type	**Individual assignment — performed on your own laptop**
Attack Technique	**Credential Harvest (simulated, benign)**
Submission	**One PDF uploaded on the university portal only**
Deliverable	**Worksheet Sections 1– 6 (Appendix A) with one screenshot per section**

1. Objectives

By the end of this assignment, students will be able to:

- Understand how a phishing email looks and behaves.
- Identify phishing indicators in the sender, subject, greeting, body and links of an email.
- Experience a controlled, authorised phishing simulation.
- Explain how a credential-harvesting attack works from email to fake login page.
- Inspect a link and message headers without clicking anything.
- Report a suspicious email using the built-in Outlook reporting option.
- Analyse the results of a simulation (delivered, clicked, compromised, reported).
- Explain why real credentials should never be entered into an unknown page.

2. Assignment Instructions (Read Carefully)

General Instructions

- This is an **individual assignment**. Every student performs all tasks personally and submits their own work.
- Perform this assignment on **your own laptop** (or your personal computer at home). **Do not use university lab computers.** Work done on university computers will not be accepted, and you must never leave your university account signed in on a shared machine.
- Sign in only with **your own university Microsoft 365 account**. Do not use a classmate's account or a personal email account.
- Complete all six sections of the worksheet (Appendix A). **Attach a screenshot for every section (1, 2, 3, 4, 5 and 6)** in the box provided under that section. A section submitted without its screenshot receives **0 marks for that section**.

Screenshot Rules

- Take a **full-screen** screenshot (Windows: **Win + Shift + S** or **PrtScn**; macOS: **Cmd + Shift + 3**).
- The **taskbar date and time** and **your own signed-in Outlook account name** must be visible in every screenshot.
- Do **not** crop, edit, or reuse screenshots from anyone else. Edited or borrowed screenshots are treated as cheating.
- Never share your screenshots with classmates or post them on WhatsApp groups or social media.

Academic Integrity — Zero Tolerance

- **No cheating.** Do your own original work and write every answer in your own words.
- If your submission is copied, or **matches another student's submission** in the class, **all students involved will receive 0 (zero) marks**. It does not matter who copied from whom.
- Copying text from the internet or from any other source without doing the work yourself is also cheating and receives 0 marks.

Deadline and Submission

- Submit **before the deadline**. **The deadline will not be extended** for any reason, and late submissions will not be accepted.
- Submit **only on the university portal**. Submissions by email, WhatsApp or any other channel will not be accepted.
- Submit **one PDF file** named **RollNo_PhishingAssignment.pdf** (for example, 25F-1234_PhishingAssignment.pdf).
- Do not wait for the last hour. Portal or internet problems at the last minute are not accepted as a reason for a late submission.

3. Marking Scheme

Section	What is assessed	Marks
1 — Email examination	Correct sender analysis and at least three indicators + screenshot	20
2 — Link inspection	Real URL and domain identified, mismatch explained + screenshot	20
3 — Header analysis	Header fields and spf/dkim/dmarc results recorded correctly + screenshot	15
4 — Reporting	Email reported, time recorded + screenshot	15
5 — Attack path diagram	Own diagram using own email details, missed indicators, explanation + screenshot	15
6 — Class results	Rates calculated with formulas, interpretation + screenshot	15
	Total	100

A section without its screenshot receives 0 marks. Copied or matching submissions receive 0 marks for the whole assignment, for all students involved.

4. Requirements

- **Your own laptop** (Windows or macOS) with an internet connection. University lab computers are not allowed.
- Your university Microsoft 365 account with access to **Outlook on the web** (outlook.office.com).
- A desktop browser (Edge or Chrome). Mobile Outlook is not used in this assignment.
- Microsoft Word (or any editor) to fill this worksheet and export it to PDF.
- Excel or Google Sheets for the calculation in Task 6.

5. Safety Rules (Read Before Starting)

Safety Rules — all students must follow these

- **Never type your real university password** into any page opened from an email during this assignment.
- The simulation is authorised and benign. It does not install anything and is only used for learning.
- Clicking the link in the simulation is **not** marked against you. Marks come from your worksheet and screenshots, not from whether you clicked.
- Do not forward the simulation email to anyone outside the class or post screenshots of it publicly.
- If you accidentally click the link: close the tab, type nothing, inform the instructor, and continue with the assignment.
- Only university-provided accounts are used. Personal email accounts are never part of this assignment.

6. Background

6.1 What is phishing?

Phishing is a social-engineering attack in which an attacker sends a message that pretends to come from a trusted source (IT department, bank, courier, teacher) to trick the reader into clicking a link, opening a file, or giving away information such as a password. It targets people, not software, which is why awareness is the main defence.

6.2 Psychological levers attackers use

Lever	How it appears in an email
Urgency	"Act within 24 hours", "Final notice", "Immediate action required"
Fear / Threat	"Your account will be suspended", "Unusual sign-in detected"
Authority	Pretends to be IT Helpdesk, the Registrar, a Head of Department
Reward / Curiosity	"Scholarship refund pending", "You have a shared document: Final Grades"
Routine	Looks like an everyday notification: password expiry, voicemail, invoice

6.3 How a credential-harvesting attack works

1. **Lure:** the victim receives an email that looks legitimate (e.g., "Your password expires today").
2. **Click:** the victim clicks a link whose visible text hides a different real destination.
3. **Fake login page:** a page copying a real sign-in screen asks for username and password.
4. **Harvest:** in a real attack the typed credentials go straight to the attacker.
5. **Abuse:** the attacker signs in, reads mail, sends more phishing from the trusted account, or steals data.

In this assignment the login page is a Microsoft-hosted simulation page. The platform only records that the action happened and then shows a training (landing) page explaining the red flags.

6.4 What the simulation measures

Metric	Meaning
Delivered	The simulated email reached the student's inbox.
Clicked	The student opened the link in the email.
Compromised	The student submitted something on the simulated login page.
Reported	The student reported the email as phishing — the desired behaviour.
Training status	Whether the assigned awareness training is completed.

Part A — How the Simulation Is Set Up

> **Note:** First, practise Parts A–D to understand how an organisation configures and launches a phishing simulation in a controlled environment. After completing these steps for practice, start your submission from **Part E**. Only Part E onward is required for submission.

Step 1: Open Attack Simulation Training in Microsoft Defender

Perform:

1. Open a browser and go to **https://security.microsoft.com**.
2. Sign in with the account that has the Attack Simulation Administrator role.
3. From the left menu, open **Email & collaboration → Attack simulation training**.
4. Select the **Simulations** tab (direct link: security.microsoft.com/attacksimulator?viewid=simulations).

Expected Outcome

- The Attack simulation training page opens with tabs such as Overview, Simulations, Training, Reports and Content library.
- A **Launch a simulation** button is visible on the Simulations tab. If the menu item is missing, the licence or role is not assigned.

Part B — Create the Student Simulation

Step 2: Select the technique

Perform

1. On the Simulations tab, select **Launch a simulation**.
2. On the **Select technique** page, choose **Credential Harvest**.
3. Select **View details** to read the simulation steps, then select **Next**.

Expected Outcome

- Credential Harvest is selected and the wizard moves to the Name simulation page.
- The details flyout shows the flow: email → link → login page → landing page.

Step 3: Name and describe the simulation

Perform

1. Name: **Cyber Security Lab – Phishing Awareness Test 01**
2. Description: **This is an authorized educational phishing simulation conducted for Cyber Security students. No real passwords or personal credentials should be submitted.**
3. Select **Next**.

Expected Outcome

- The simulation now has a name. From this point, **Save and close** can store it as a Draft if setup must be paused.

Step 4: Select a built-in payload and login page

Perform

1. Stay on the **Global payloads** tab (built-in Microsoft payloads; no custom malicious site is created).
2. Select **Filter → Filter by theme** and choose **Account Verification** or **Password**. Set **Language: English** and **Complexity: Medium**. Select **Apply**.
3. Click a payload row (not the check box) to open its details flyout and preview the email.

4. Open the **Login page** tab in the flyout and preview the simulated login page (Page 1 / Page 2). Close the flyout.
5. Tick the check box next to the chosen payload and select **Next**.

Expected Outcome

- A built-in payload such as an account-verification or password-expiry email is selected.
- The preview shows the sender name, subject, body and a simulated login page. The **Predicted compromise rate** of the payload is visible for later comparison.

Part C — Select Students

Important

- Do **not** send the simulation to the entire university. Target only the students in this course. For a first run, 5–10 students is recommended; then scale up to the full class once the process is verified.

Step 5: Create a dedicated student group

Perform

1. Open the Microsoft 365 admin center (**admin.microsoft.com**) → **Teams & groups → Active teams & groups** (or ask IT to do this).
2. Select **Add a group** → choose **Mail-enabled security** (or Microsoft 365 group).
3. Name the group **CyberSecurity-Lab-Students** and add only the students enrolled in this course section as members.
4. Make sure membership is **not hidden** (hidden-membership groups are not supported by the simulator).

Expected Outcome

- The group CyberSecurity-Lab-Students exists and contains only the enrolled students.
- Group creation can take a few minutes to appear in Defender searches.

Step 6: Target the group and exclude staff

Perform

1. Back in the wizard, on **Target users**, choose **Include only specific users and groups**.
2. Select **Add users**, type **CyberSecurity** in the search box, press Enter, tick the group and select **Add users**.
3. Select **Next**. On **Exclude users**, tick **Exclude some of the targeted users** and add any instructor or TA accounts if they are in the group.
4. Select **Next**.

Expected Outcome

- Only the student group appears in the Targeted users list.
- Staff accounts are excluded so that results reflect students only.

Part D — Training, Landing Page and Launch

Step 7: Assign training

Perform

1. On **Assign training**, keep **Microsoft training experience (Recommended)**.
2. Keep **Assign training for me (Recommended)**.
3. Set **Select a training due date** to **7 days after simulation ends**. Select **Next**.

Expected Outcome

- Students who click or get compromised automatically receive a short Microsoft awareness training module with a 7-day deadline.

Step 8: Select the phish landing page

Perform

1. Choose **Use landing pages from library**.
2. Tick **Add payload indicators to email** so the landing page highlights the red flags in the original email.
3. On **Global landing pages**, select a Microsoft landing page template; set **Select default language: English**. Optionally upload the university logo.
4. Click the row to open **Preview**, check the page, then select **Next**.

Expected Outcome

- A student who reaches the end of the attack path sees a teaching page ("this was a simulation") with the suspicious parts of the email marked.

Step 9: Configure end-user notifications

Perform

1. Choose **Microsoft default notification (recommended)** and set **Select default language: English**.
2. For the positive reinforcement notification, choose **Deliver during campaign**.
3. For the training reminder notification, choose **Weekly**. Select **Next**.

Expected Outcome

- Students who report the email receive a "well done" message immediately, which reinforces correct behaviour.

Step 10: Set the launch details

Perform

1. Choose **Schedule this simulation to be launched later** and set the date/time to the assignment release date.
2. Set **Configure number of days to end simulation after** to **2** (the minimum).
3. Select **Next**.

Expected Outcome

- The simulation is delivered on the release date and stops collecting activity two days later.
- The assignment deadline is set **after** the simulation ends, so that class results can be posted on the portal for Task 6.

Step 11: Send yourself a test and review

Perform

1. On the **Review simulation** page, select **Send a test**. The payload email is sent to your own mailbox.
2. Open your inbox and verify every item in the checklist below.
3. Select **Edit** on any section that needs a change. When everything is correct, select **Submit**, then **Done**.

Expected Outcome

- The test copy arrives in the instructor mailbox and passes the checklist.
- On the Simulations tab, the simulation appears with Status **Scheduled**, then **In progress** at launch time.

Check	What to confirm	OK
Sender name	Looks like a plausible service, not a real university staff member	☐
Subject	Uses urgency or fear (good for the exercise)	☐
Email wording	Nothing offensive, controversial or tied to a real tragedy	☐
Link	Points to the Microsoft simulation domain, not a real external site	☐
Login page	Built-in Microsoft simulation page (no real credential collection)	☐
Landing / training page	Displays correctly and shows payload indicators	☐

Part E — Student Assignment Tasks

On **your own laptop**, sign in to **outlook.office.com** with your university account. The simulated email arrives in your mailbox on the release date. **Do not click anything inside the email.** Record every finding in the worksheet (Appendix A) and paste the required screenshot under each section. Complete Tasks 1–4 within two days of the release date, while the simulation is active.

Task 1: Examine the email without clicking

Perform

1. Locate the simulated email in your Inbox (check **Other** and **Junk Email** if it is not in Focused).
2. Open the email in the reading pane. Do not click any link or button in the body.
3. **Sender:** select the sender's display name to reveal the full email address. Write down the display name and the actual address, and compare the domain with the university domain.
4. **Subject:** copy the subject line and mark words that create urgency or fear.
5. **Greeting:** note whether it uses your name or a generic greeting such as "Dear User".
6. **Message:** underline urgency, threats, unusual requests, grammar problems and odd wording.
7. Take a full-screen screenshot of the open email (date/time and your account name visible) and paste it under Section 1 of the worksheet.

Expected Outcome

- The display name looks trustworthy but the real address belongs to an unrelated domain.
- At least three indicators are recorded, e.g., urgent subject, generic greeting, threat of account suspension, request to sign in.

Task 2: Inspect the link without clicking it

Perform

1. Hover the mouse pointer over the link or button in the email body. Do **not** click.
2. Read the real destination URL shown in the tooltip or in the browser's bottom-left status bar.
3. Right-click the link → **Copy link**, then paste it into Notepad (not the address bar).
4. Identify the domain: the part immediately before the first single "/" after "https://". Record it in Section 2 of the worksheet.
5. Take a full-screen screenshot **while hovering**, so the real URL tooltip or status-bar URL is visible, and paste it under Section 2.
6. Compare the visible link text with the real destination.

Expected Outcome

- The visible text (e.g., "Verify Account" or a familiar-looking address) differs from the real destination.
- The real domain is not the university or Microsoft sign-in domain, confirming that the link is a disguise.

Task 3: Inspect the message headers

Perform

1. In the open email, select **… (More actions) → View → View message details**.
2. Find and record these header fields in Section 3 of the worksheet: **From**, **Return-Path**, **Reply-To** (if present), **Received** (the first/bottom-most server) and **Authentication-Results**.
3. In Authentication-Results, record the result of **spf**, **dkim** and **dmarc** and the domain each one checked.
4. Take a full-screen screenshot of the message details window showing the Authentication-Results lines, and paste it under Section 3.
5. Close the message details window.

Expected Outcome

- The Return-Path and authenticated domain do not match the brand or organisation the email claims to come from.
- Students learn that headers reveal the true sending infrastructure, which the display name can hide.

Task 4: Report the email as phishing

Perform

1. With the simulated email selected, open the **Report** option on the toolbar (or **… → Report → Report phishing**).
2. Choose **Report phishing** and confirm in the dialog.
3. Check your inbox for a positive-reinforcement message from the simulation.
4. Take a full-screen screenshot of the report confirmation or the positive-reinforcement message, paste it under Section 4, and record the time you reported.

Expected Outcome

- The email is removed from the Inbox and the action is recorded as **Reported** in the simulation.
- A "thank you for reporting" notification arrives, confirming the correct response.

Task 5: Draw the attack path of YOUR email

Perform

1. Watch the instructor's attack-path walkthrough (shown in class and posted on the portal): email → link click → simulated login page → landing page with payload indicators.
2. On your laptop, draw your **own** attack-path diagram with four labelled stages (use draw.io, PowerPoint, Word shapes, or draw by hand on paper).
3. Fill each stage with details from **your** email: the sender and subject from Task 1, the real link domain from Task 2, and what the login page would ask for.
4. Under the diagram, write (a) the indicators shown on the landing page that you **missed** in Tasks 1–3 and (b) in 3–4 lines of your own words, why real credentials must never be entered on a page opened from an email link.
5. Write your **name and roll number** on the diagram. Take a full-screen screenshot (or a clear photo, if hand-drawn) and paste it under Section 5.

Expected Outcome

- A diagram that is clearly your own: it uses the details of your email and shows your name and roll number.
- Missed indicators are listed, and the danger of entering credentials is explained in your own words.

Part F — Analyse the Simulation Results

After the simulation ends, the instructor posts the **class-level totals** (delivered, clicked, compromised, reported) and the payload's **predicted compromise rate** on the portal. No individual student is named.

Task 6: Calculate and interpret the class results

Perform

1. Open Excel or Google Sheets on your laptop. In cell A1 type your **name and roll number**.
2. Enter the four class totals from the portal in separate cells.
3. Using **formulas** (not typed answers), calculate: Click rate = Clicked ÷ Delivered × 100; Compromise rate = Compromised ÷ Delivered × 100; Report rate = Reported ÷ Delivered × 100.
4. Compare the actual compromise rate with the predicted compromise rate and write a 2–3 line interpretation in your own words in Section 6.

5. Take a full-screen screenshot of the sheet with one formula visible in the formula bar, and paste it under Section 6.

Expected Outcome

- Three correctly calculated rates, produced by formulas and recorded in Section 6.
- A short interpretation explaining that a high report rate and a low compromise rate are the goals of awareness training.

Instructor clean-up (after the assignment)

- Leave the simulation to finish automatically (2 days) or use ⋮ → **Cancel simulation** if needed; links are then deactivated.
- Export or note the final results for the course record.
- Remove students from **CyberSecurity-Lab-Students** or delete the group when the course ends.

Phishing Indicator Reference

Indicator	What to look for	Example
Sender mismatch	Display name and real address/domain differ	"IT Helpdesk" <alerts@mail-verify-center.example>
Urgency	Short deadlines, "final notice"	"Verify within 24 hours"
Threat	Loss of access, penalties	"Your mailbox will be deactivated"
Generic greeting	No name, or name taken from email address	"Dear User", "Dear Student"
Disguised link	Link text differs from real URL	Text: portal.university.edu → Real: login-portal-check.example
Look-alike domain	Extra words, swapped letters, wrong TLD	micros0ft-support.example, univ-edu.example
Credential request	Asks you to sign in or "confirm" a password	"Re-enter your password to keep your account"
Unusual tone / errors	Odd grammar, spelling, formatting	"Kindly do the needful to verify you account"
Unexpected attachment	Files you did not request (.html, .zip, .docm)	Invoice_8812.html
Header failures	spf / dkim / dmarc = fail or mismatched domain	dmarc=fail header.from=…

Practice Exercise (Optional — Not Graded)

The following three messages are fictional examples created for practice. The organisation "Northfield University" and every domain ending in **.example** are invented and do not exist.

Sample 1

Field	Content
From	Northfield IT Helpdesk <support@northfield-mailcenter.example>
Subject	URGENT: Mailbox Deactivation Within 24 Hours
Body	Dear User, Our system detected that your mailbox has exceeded its limit and will be deactivated today. To avoid losing your emails, kindly verify you account immediately by clicking below. Failure to do so will result in permanent suspension.
Link text → real URL	"portal.northfield.edu/verify" → http://northfield-mailbox-verify.example/login

Sample 2

Field	Content
From	Accounts Office <accounts.office.nfu@freemail.example>
Subject	Scholarship Refund of Rs. 45,000 Pending – Action Needed
Body	Congratulations! You are eligible for a scholarship refund. Please confirm your bank account details and student portal password using the secure form below before Friday so that the amount can be transferred.
Link text → real URL	"Claim Refund" → https://nfu-refunds-portal.example/form

Sample 3

Field	Content
From	Dr. A. Rehman via DocuShare <no-reply@docushare-files.example>
Subject	Dr. A. Rehman shared "Final Exam Grades.xlsx" with you
Body	You have received a shared document. Sign in with your university account to view it. This link expires in 2 hours.
Link text → real URL	"Open Document" → https://docushare-files.example/northfield/signin

Practice A: Analyse the three samples

Perform

1. For each sample, list every indicator using the Phishing Indicator Reference table.
2. For each sample, write the real domain of the link and explain in one line why it is not trustworthy.
3. Rank the three samples from most to least convincing and give a one-line reason for each.

Expected Outcome

- A table with at least four indicators per sample, the real domain of every link, and a ranked list with reasons.

Practice B: Create a one-page awareness guide

Perform

1. Design a one-page guide titled **"Spot It, Don't Click It"** for first-year students.
2. Include: five warning signs, how to hover-check a link, how to report a phishing email in Outlook, and what to do if a password was entered by mistake (change it immediately, enable MFA, inform IT).
3. Use your own words and your own design (Word, Canva or PowerPoint; export to PDF).

Expected Outcome

- A clear, one-page PDF that a non-technical student can follow in under two minutes.

Appendix A — Phishing Analysis Worksheet

Name: _____ Roll No: _____ Section: _____ Date: _____

Section 1 — Email Examination (Task 1)

Field	Your finding
Sender display name	
Actual sender address	
Subject line	
Greeting (personal / generic)	
Urgency or threat words	
Grammar / wording issues	
What the email asks you to do	

Screenshot — Section 1 (paste here)

Must show: the simulated email open in Outlook on the web, with the taskbar date/time and your account name visible.

Section 2 — Link Inspection (Task 2)

Field	Your finding
Visible link text	
Real destination URL	
Real domain	
Match? (Yes / No)	

Screenshot — Section 2 (paste here)

Must show: the mouse hovering over the link with the real destination URL visible (tooltip or status bar).

Section 3 — Header Analysis (Task 3)

Field	Your finding
From	
Return-Path	
Reply-To	

Field	Your finding
First Received server	
spf result / domain	
dkim result / domain	
dmarc result	

Screenshot — Section 3 (paste here)

Must show: the message details window with the Authentication-Results (spf, dkim, dmarc) lines visible.

Section 4 — Reporting (Task 4)

Field	Your finding
Time reported	
Confirmation received (Yes / No)	

Screenshot — Section 4 (paste here)

Must show: the Report phishing confirmation or the positive-reinforcement message in your mailbox.

Section 5 — Attack Path Diagram (Task 5)

Field	Your finding
Stage 1: Email	
Stage 2: Link click	
Stage 3: Login page (what it asks for)	
Stage 4: Landing page	
Indicators I missed	
Why real credentials must never be entered (own words)	

Screenshot — Section 5 (paste here)

Must show: your own attack-path diagram with your name and roll number written on it.

Section 6 — Class Results (Task 6)

Field	Your finding
Delivered	
Clicked	
Compromised	
Reported	
Click rate (%)	
Compromise rate (%)	
Report rate (%)	
Predicted vs actual compromise rate	
Interpretation (own words)	

Screenshot — Section 6 (paste here)

Must show: your spreadsheet with your name/roll number in A1 and a formula visible in the formula bar.

Submission Checklist

#	Item	Done
1	Assignment performed on **my own laptop**, not on a university computer	☐
2	Worksheet Sections 1–6 completed in my own words	☐
3	Screenshot attached under **each** of Sections 1, 2, 3, 4, 5 and 6	☐
4	Every screenshot is full-screen with date/time and my account name visible	☐
5	Attack-path diagram shows my name and roll number	☐
6	Spreadsheet uses formulas and shows my name/roll number	☐
7	No real password entered at any point	☐
8	Single PDF named **RollNo_PhishingAssignment.pdf**	☐
9	Uploaded on the **university portal** before the deadline	☐

Reminder: the deadline will not be extended. Submissions by email or WhatsApp are not accepted. Copied or matching work receives 0 marks.